

Module 2: The Cyber Kill Chain

What is the Cyber Kill Chain?

The **Cyber Kill Chain** is a seven phase model developed by Lockheed Martin that describes the stages of a targeted cyber attack. It was originally published in 2011 and remains one of the most widely used frameworks for describing and communicating attack progressions.

Note: AttackMate is designed to automate attacks across *all* phases of the Kill Chain. The playbooks you have been writing in days 1-2 already cover several phases. Today, you will build a playbook that covers all seven.

The Seven Phases

Phase 1: Reconnaissance

The attacker gathers information about the target before attempting anything.

Goal: Identify exploitable services, open ports, running software versions, and potential credential weaknesses.

Techniques in today's lab:

- `nmap` port scan to identify open services and version numbers
- Banner grabbing (`nc <TARGET> 21, nc <TARGET> 139`)
- Identifying the target OS from scan results

AttackMate commands used:

- `shell` (nmap, netcat)
- `regex` (parse nmap output, extract open ports and versions)

Defender note: Active scanning generates network traffic that network monitoring tools (IDS/IPS, firewall logs) can detect.

Phase 2: Weaponization

The attacker prepares the exploit or payload before launching the attack. The target is not touched during this phase.

Goal: Create a working payload or identify a known exploit that matches a discovered vulnerability.

Techniques in today's lab:

- Looking up a vulnerability/exploit
- Generating a reverse shell binary with `msf-payload`

AttackMate commands used:

- `msf-payload` (generate ELF/exe binaries)

Defender note: Weaponization happens entirely on the attacker's infrastructure. Defenders cannot observe it directly, but threat intelligence can flag known payload signatures.

Phase 3: Delivery

The attacker moves the weapon to the target environment.

Goal: Get the payload or exploit to a position where it can execute on the target.

Techniques in today's lab:

- Metasploit `exploit/...` module sending the exploit payload over the network
- Hosting a payload binary and triggering a download from the target via PHP RCE
- `webserv` serving the payload on a local port

AttackMate commands used:

- `webserv` (background file server)
- `msf-module` (exploit delivery)

Defender note: Delivery generates network activity. Unusual outbound connections from servers to attacker-controlled IPs or unexpected file downloads are detectable by network monitoring and web proxy logs.

Phase 4: Exploitation

The exploit runs and code executes on the target.

Goal: Execute attacker-controlled code on the target system.

Techniques in today's lab:

- vsftpd 2.3.4 backdoor: connecting to port 6200 after triggering the backdoor via port 21
- Samba usermap_script: SMB request with crafted username triggers shell command execution
- PHP-CGI argument injection: HTTP request causes PHP interpreter to execute attacker arguments
- SSH with weak credentials: successful login with known-default credentials

AttackMate commands used:

- `msf-module` (exploit/...)
- `ssh` (login with discovered credentials)

Defender note: Exploitation often appears in service-specific logs (FTP, Samba, Apache) as unusual requests or errors.

Phase 5: Installation

The attacker establishes persistence so that access survives reboots, session drops, and password changes.

Goal: Ensure continued access even if the initial shell dies.

Techniques in today's lab:

- Adding an SSH public key to `~/.ssh/authorized_keys` (survives password changes)
- Creating a cron job that phones home periodically
- Adding a new user account with a known password

AttackMate commands used:

- `sftp` (upload SSH key)
- `ssh` or `msf-session` (run commands to add user, write cron)
- `shell` (generate keypair with `ssh-keygen` on attacker)

Defender note: Changes to `~/.ssh/authorized_keys`, `/etc/passwd`, `/etc/cron.d/`, and `/etc/crontab` are high-signal persistence indicators. File integrity monitoring (FIM) tools specifically watch these files.

Phase 6: Command and Control (C2)

The attacker establishes a reliable, ongoing channel to issue commands and receive output.

Goal: Maintain an interactive, reliable connection to the compromised system.

Techniques in today's lab:

- Meterpreter session over Metasploit (encrypted, interactive)
- Raw shell session via Metasploit (unencrypted, limited interactivity)
- SSH session (encrypted, reliable)
- Sliver beacon (async C2, encrypted)

AttackMate commands used:

- `msf-session` (issue commands into Metasploit sessions)
- `ssh` (ongoing session)
- `sliver-session` (Sliver implant sessions)

Defender note: C2 channels produce ongoing outbound network connections. Unusual long-lived TCP connections, connections to non-standard ports, or periodic "beaconing" patterns are detectable by network flow analysis.

Phase 7: Actions on Objectives

The attacker accomplishes their actual goal.

Goal: Do whatever the attack was intended to do; steal data, dump credentials, cause disruption, pivot to other systems.

Techniques in today's lab:

- System discovery (hostname, OS version, users, running processes)

- Credential dumping (`/etc/shadow`, `hashdump`)
- File collection (find and read sensitive files)
- Exfiltration (SFTP download, Meterpreter download, netcat transfer)
- Log review (read `auth.log` to see your own attack's footprint)

AttackMate commands used:

- `msf-session` (post-exploitation commands)
- `ssh` (command execution)
- `sftp` (file download)
- `shell` (local file operations on attacker machine)

Defender note: Data access and exfiltration are often the "noisiest" phase. Large file reads, unexpected outbound data transfers, and access to `/etc/shadow` by non-root processes are all detectable.

Kill Chain vs. Reality

The Kill Chain is a useful teaching model, but real attacks are usually messier:

- Attackers may skip phases (e.g., no persistence needed for a smash-and-grab)
- Phases can overlap (exploitation and installation happening in the same step)
- Attackers often revisit phases (pivot to a new machine starts a new reconnaissance phase)

For a more granular, technique-level view that handles these complexities, the MITRE ATT&CK framework is a better fit.

Further Reading

- [Lockheed Martin - Intelligence-Driven Computer Network Defense](#) - the original Kill Chain paper
- [AttackMate on ArXiv](#) - *"Realistic Emulation and Automation of Cyber Attack Scenarios Across the Kill Chain"*